

BÁO CÁO BẢO VỆ ĐỒ ÁN TỐT NGHIỆP / MÔN HỌC

ĐỀ TÀI: NEXTECH - NỀN TẢNG THƯƠNG MẠI ĐIỆN TỬ THIẾT BỊ CÔNG NGHỆ TIÊU DÙNG CHUYÊN SÂU

Sinh viên thực hiện: Đặng Quang Trung

Email: trungdang.dqt@gmail.com | **GitHub:** Quang-Trung-68

Giảng viên hướng dẫn: [Tên Giảng Viên Hướng Dẫn]

Trường/Khoa: [Tên Trường / Khoa Công Nghệ Thông Tin]

1. Bối Cảnh & Bài Toán Thực Tế

- **Sự bùng nổ của TMĐT thiết bị công nghệ:** Thị trường điện thoại, laptop, máy tính bảng tại Việt Nam tăng trưởng 15-20%/năm, nhu cầu mua sắm online ngày càng cao.
- **Thiếu nền tảng chuyên sâu:** Các sàn TMĐT phổ thông (Shopee, Lazada) không giải quyết triệt để các nghiệp vụ đặc thù của ngành hàng công nghệ.
- **Đòi hỏi trải nghiệm mượt mà:** Khách hàng kỳ vọng thanh toán nhanh, thông báo tức thời, hỗ trợ AI và hóa đơn đầy đủ.

→ **NexTech** ra đời nhằm lấp đầy khoảng trống này.

2. Thách Thức Đặc Thù Của Ngành Hàng Công Nghệ

- **Quản lý kho theo IMEI/Serial:** Mỗi thiết bị có mã định danh riêng, cần theo dõi từ nhập kho → bán → bảo hành. Không thể quản lý như quần áo hay thực phẩm.
- **Hóa đơn VAT cho doanh nghiệp:** Khách hàng doanh nghiệp yêu cầu xuất hóa đơn đủ đúng chuẩn, không thể sửa đổi sau khi xuất.
- **Bảo mật tài khoản:** Chống tấn công XSS/CSRF chiếm đoạt tài khoản, đặc biệt khi tích hợp nhiều cổng thanh toán.
- **Đồng bộ thanh toán bất đồng bộ:** Webhook từ Stripe/SePay có độ trễ, cần xử lý transactional đảm bảo toàn vẹn dữ liệu.

3. Mục Tiêu — Về Mặt Hệ Thống

- **Kiến trúc Monorepo:** Tổ chức mã nguồn tập trung, dễ quản lý, chia sẻ code chung giữa các package.
 - `frontend/`: React SPA cho người dùng
 - `admin/`: React CMS cho quản trị viên
 - `backend/`: Express REST API
 - `nginx/`: Reverse proxy configuration
 - `scripts/`: Deploy automation
- **Thiết kế REST API theo mô hình Layered:**

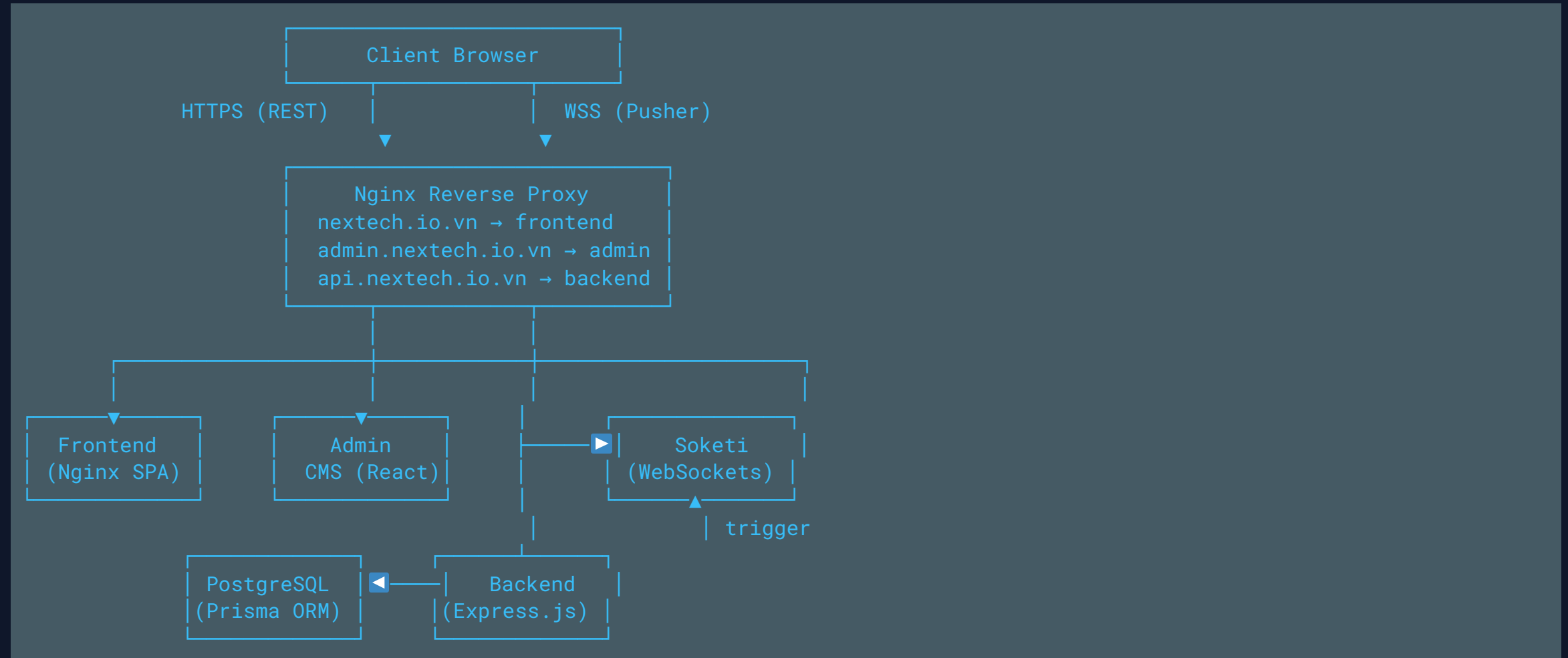
Routes (định tuyến) → Controllers (xử lý request) → Services (logic nghiệp vụ) → Prisma (truy vấn DB)
- **Đóng gói Docker:** Toàn bộ hệ thống chạy trong container, triển khai nhất quán trên mọi môi trường.

4. Mục Tiêu — Về Mặt Nghiệp Vụ & Trải Nghiệm

- **Quản lý vòng đời thiết bị:** `SerialUnit` với 4 trạng thái `IN_STOCK` → `RESERVED` → `SOLD` → `RETURNED`, truy xuất lịch sử bảo hành từ IMEI.
- **Thanh toán kép tự động:** Stripe (thẻ quốc tế) + SePay/VietQR (chuyển khoản nội địa) — cả hai đều qua Webhook, zero manual intervention.
- **Thông báo thời gian thực:** WebSocket qua Socketi (Pusher protocol), private channel cho từng người dùng, toast popup + badge count.
- **AI Chatbot:** Trợ lý mua sắm thông minh tích hợp Gemini API, gợi ý sản phẩm theo nhu cầu.
- **Hóa đơn VAT tự động:** PDFKit sinh file PDF, gửi email cho khách hàng doanh nghiệp.

5. Kiến Trúc Tổng Quan Hệ Thống

Nginx Reverse Proxy điều phối 5 dịch vụ, tất cả đóng gói trong Docker Containers:



6. Công Nghệ — Frontend (User)

Thành phần	Công nghệ	Vai trò
Framework	React 19	Xây dựng giao diện SPA, server component, hook mới
Build tool	Vite 8	Dev server HMR cực nhanh, build tối ưu
Routing	React Router v7	Điều hướng SPA, load data theo route
CSS	Tailwind CSS v3 + Shadcn/UI	Utility-first, component library tùy biến cao
State (server)	TanStack Query v5	Cache & đồng bộ dữ liệu API, background refetch
State (local)	Zustand	Quản lý global state nhẹ, không boilerplate
Forms	react-hook-form + Zod	Validate dữ liệu đầu vào mạnh mẽ
Icons	Lucide React	Bộ icon open-source, consistent
HTTP	Axios	Interceptor, refresh token tự động

7. Công Nghệ — Admin CMS

Thành phần	Công nghệ	Vai trò
Framework & UI	React 19 + Shadcn/UI	Giao diện quản trị thống nhất với user frontend
Data Table	TanStack Table	Phân trang, sort, filter, column visibility cho danh sách đơn hàng, sản phẩm
Dashboard Charts	Recharts	Biểu đồ doanh thu, số lượng đơn hàng theo thời gian
Rich Text Editor	TipTap	Soạn thảo bài viết tin tức công nghệ, blog
Real-time	pusher-js	Nhận thông báo đơn hàng mới tức thời
State Management	TanStack Query v5 + Zustand	Giống frontend user
Dark Mode	next-themes	Hỗ trợ giao diện sáng/tối

8. Công Nghệ — State Management & Caching

Chiến lược quản lý state 2 tầng:

TanStack Query v5 (Server State)

- **Cache API responses:** Tự động caching, background refetch, stale-while-revalidate
- **Optimistic updates:** Cập nhật UI ngay lập tức trước khi API response
- **Infinite staleTime cho admin badge:** `staleTime: Infinity` tránh reset badge count về 0
- **setQueryData:** Increment unread count thay vì `invalidateQueries` — tránh flash trắng

Zustand (Local/Client State)

- **Theme preference:** Sáng/tối
- **UI state:** Sidebar mở/đóng, modal state
- **Form draft:** Lưu tạm dữ liệu form khi người dùng chưa submit

9. Công Nghệ — Backend API

Thành phần	Công nghệ	Chi tiết
Runtime	Node.js 20	Non-blocking I/O, phù hợp xử lý bất đồng bộ Webhook
Framework	Express 4	Routing, middleware, error handling
Authentication	Passport.js	Chiến lược JWT, OAuth2 (Google)
JWT	jsonwebtoken	Access token (1h) + Refresh token (7d)
Cookie	cookie-parser + COOKIE_SECRET	HttpOnly, SameSite, ký chữ ký
ORM	Prisma	Type-safe queries, migration, schema-first
Validation	express-validator	Validate đầu vào request
WebSocket	Pusher SDK	Trigger events từ backend đến Sockets
Cron	node-cron	5 tác vụ nền chạy trong cùng tiến trình

10. Công Nghệ — Database & ORM

PostgreSQL 16 + Prisma ORM v7 — 37 models, schema-first approach.

- **Lý do chọn PostgreSQL:**
 - Tính toàn vẹn giao dịch cao (ACID) — quan trọng cho thanh toán và hóa đơn
 - Kiểu dữ liệu `Decimal` cho tiền tệ — tránh floating-point error
 - Hỗ trợ `@@unique` constraint — đảm bảo một serial chỉ thuộc một order
 - JSON fields cho linh hoạt mở rộng
- **Lý do chọn Prisma:**
 - Type-safe từ DB đến code — phát hiện lỗi schema lúc compile
 - Migration tự động — `prisma migrate dev` cho dev, `prisma migrate deploy` cho prod
 - Relation queries — `include` và `select` mạnh mẽ, giảm boilerplate
- **Quản lý tiền tệ:** Tất cả giá dùng `Decimal(12,2)`, không float.

11. Công Nghệ — Real-time Engine (Soketi)

Soketi — WebSocket server tự dựng, giao thức tương thích Pusher, chi phí thấp hơn Pusher SaaS.

- **Cấu hình tự dựng:**
 - Container chạy riêng trong Docker network
 - Backend trigger event qua Pusher PHP/Node SDK
 - Frontend nhận event qua `pusher-js`
 - Nginx reverse proxy: `wss://api.nextech.io.vn/app/*` → `soketi:6001`
- **Private Channel** `private-user.{userId}`:
 - Mỗi user chỉ nhận thông báo của chính mình
 - Xác thực qua endpoint `/notifications/auth` (JWT verify riêng)
 - Không ai có thể subscribe channel của người khác
- **Ưu điểm:** Độ trễ <10ms, không giới hạn concurrent connections, không tốn phí SaaS.

12. Công Nghệ — DevOps & Container

- **Docker Compose**: 5 containers trong 1 network
 - `frontend_app`: Nginx serving React build (port 3000)
 - `admin_app`: Nginx serving React build (port 3001)
 - `backend_app`: Express.js (port 5000)
 - `soketi_app`: Soketi WebSocket (port 6001)
 - `postgres_db`: PostgreSQL 16 (port 5432)
- **Nginx Reverse Proxy**: 1 entry point duy nhất (port 443)
 - Route theo subdomain: `nextech.io.vn`, `admin.nextech.io.vn`, `api.nextech.io.vn`
 - Let's Encrypt SSL tự động
- **Multi-stage builds**: Dockerfile tối ưu kích thước image, chỉ copy `node_modules` production

13. Thiết Kế CSDL — Users & Authentication

Models chính

Model	Mục đích
User	Khách hàng: email, password (hash), OAuth provider, profile
Admin	Quản trị viên: riêng biệt với User, không public register
OAuthAccount	Liên kết tài khoản Google/Facebook (provider + providerId)
RefreshToken	Lưu JWT refresh token, có thời gian hết hạn, liên kết User/Admin
RevokedToken	Blacklist token đã thu hồi — chống replay attack
PasswordResetToken	Token đặt lại mật khẩu, có expiry

Đặc điểm bảo mật

- Admin và User là 2 bảng riêng — không lộ admin endpoint cho user thường
- RefreshToken có `expiresAt` — tự động dọn dẹp job định kỳ
- RevokedToken ghi lại thời gian thu hồi — không thể dùng token cũ

14. Thiết Kế CSDL — Products & Catalog

Ma trận cấu hình sản phẩm (Product Variant Matrix)

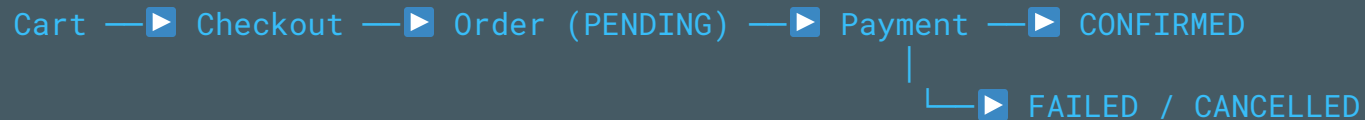
```
Product (iPhone 16 Pro)
├── ProductAttribute (Màu sắc: Xám, Vàng)
│   └── ProductAttributeValue (Gray, Gold)
├── ProductAttribute (Dung lượng: 128GB, 256GB)
│   └── ProductAttributeValue (128, 256)
└── ProductVariant (Kết hợp: Gray/128GB, Gray/256GB, Gold/128GB...)
    └── ProductVariantValue (Liên kết attribute → variant)
```

Models chính

Model	Chức năng
Product	Thông tin chung: tên, mô tả, giá gốc, brand, category
ProductImage	Gallery ảnh, ảnh đại diện, sort order
Brand	Thương hiệu (Apple, Samsung, Dell...)
Category, Tag	Phân loại và gắn thẻ sản phẩm, bài viết

15. Thiết Kế CSDL — Orders & Cart

Luồng hoạt động

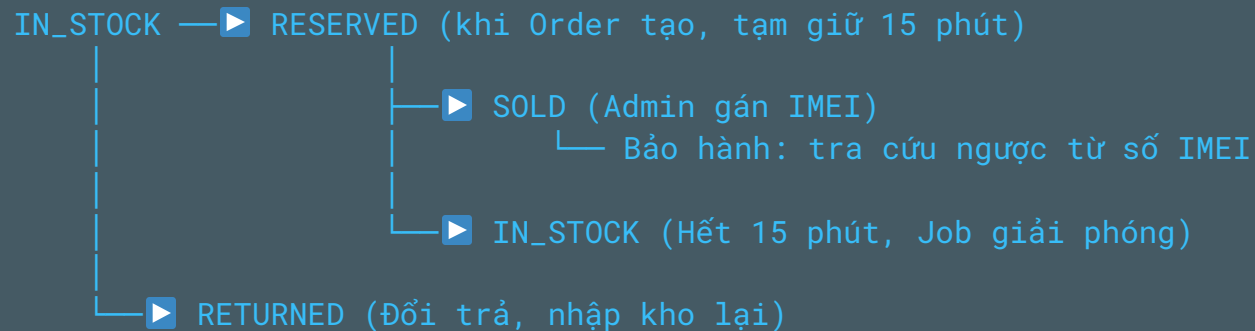


Models chính

Model	Chức năng
Cart	Giỏ hàng theo user, có expiry
CartItem	Sản phẩm trong giỏ, số lượng, variant
Order	Đơn hàng: status (PENDING → PROCESSING → CONFIRMED → SHIPPING → DELIVERED → CANCELLED), tổng tiền, shipping address
OrderItem	Chi tiết sản phẩm trong đơn (snapshot giá tại thời điểm mua)
Coupon	Mã giảm giá: percentage/flat, min order, expiry, usage limit
CouponUsage	Ghi lại ai đã dùng coupon — chống dùng lại
Review	Đánh giá sản phẩm sau khi nhận hàng

16. Thiết Kế CSDL — Serial IMEI & Kho Hàng

Vòng đời SerialUnit



Models chính

Model	Chức năng
Supplier	Nhà cung cấp: tên, liên hệ, địa chỉ
StockImport	Phiếu nhập kho: thời gian, tổng số lượng, supplier
SerialUnit	IMEI/Serial duy nhất: status, liên kết StockImport và OrderItem

Ràng buộc

- `@@unique([serialNumber, orderItemId])` — một serial chỉ gán một order item
- Tra cứu bảo hành: `IMEI → SerialUnit → OrderItem → Order → User`

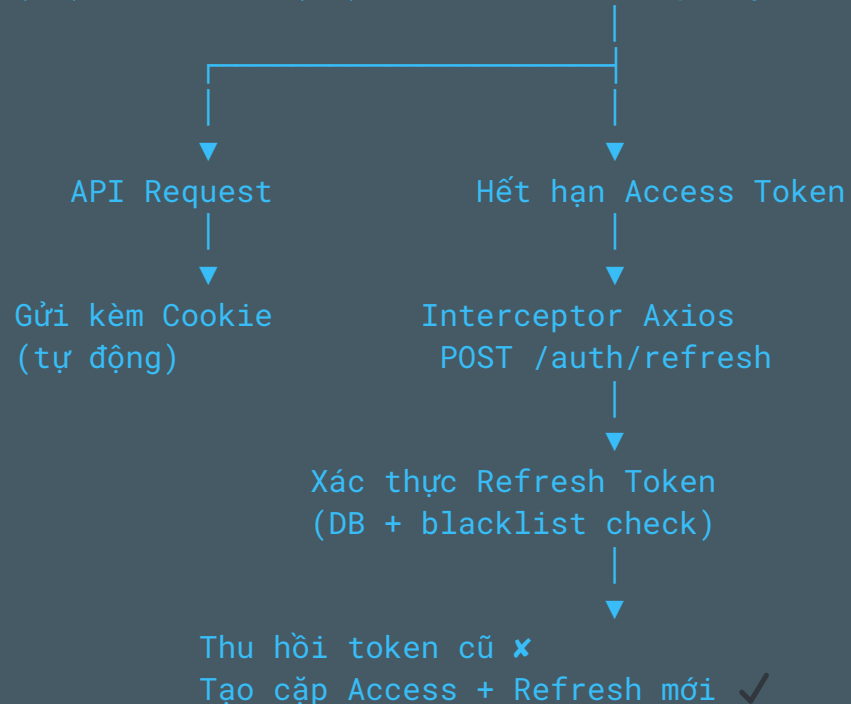
17. Thiết Kế CSDL — Tiện Ích & Vận Hành

Model	Chức năng
Notification	Thông báo real-time: user, message, type, read status
Post	Bài viết tin tức công nghệ (có scheduled publish)
Category, Tag	Phân loại bài viết (tái sử dụng với Product Category)
AIChatMessage	Lịch sử hội thoại chatbot AI (role: user/assistant, message)
ShopSettings	Cấu hình toàn cục: lowStockThreshold, orderAlertThreshold, VAT config
FailedEmail	Hàng đợi email lỗi: tự động retry qua cron job

18. Bảo Mật — Xác Thực JWT HttpOnly

Cơ chế Access/Refresh Token Rotation

Đăng nhập —▶ Tạo cặp Access (1h) + Refresh (7d) —▶ Lưu vào HttpOnly Cookie



- **Chống XSS:** Token không lưu trong `localStorage`, không thể bị đánh cắp qua JS injection
- **Chống CSRF:** Cookie `SameSite: Lax` + ký request signature qua `COOKIE_SECRET`

19. Bảo Mật — Pusher Private Channel Authentication

Vấn đề

- User và Admin dùng chung backend
- User có thể đã login admin trước đó (cookie `admin_access_token` tồn tại)
- Notification API user bị sai vì middleware ưu tiên admin token

Giải pháp

Endpoint POST /notifications/auth (BYPASS middleware protectUserOrAdmin)

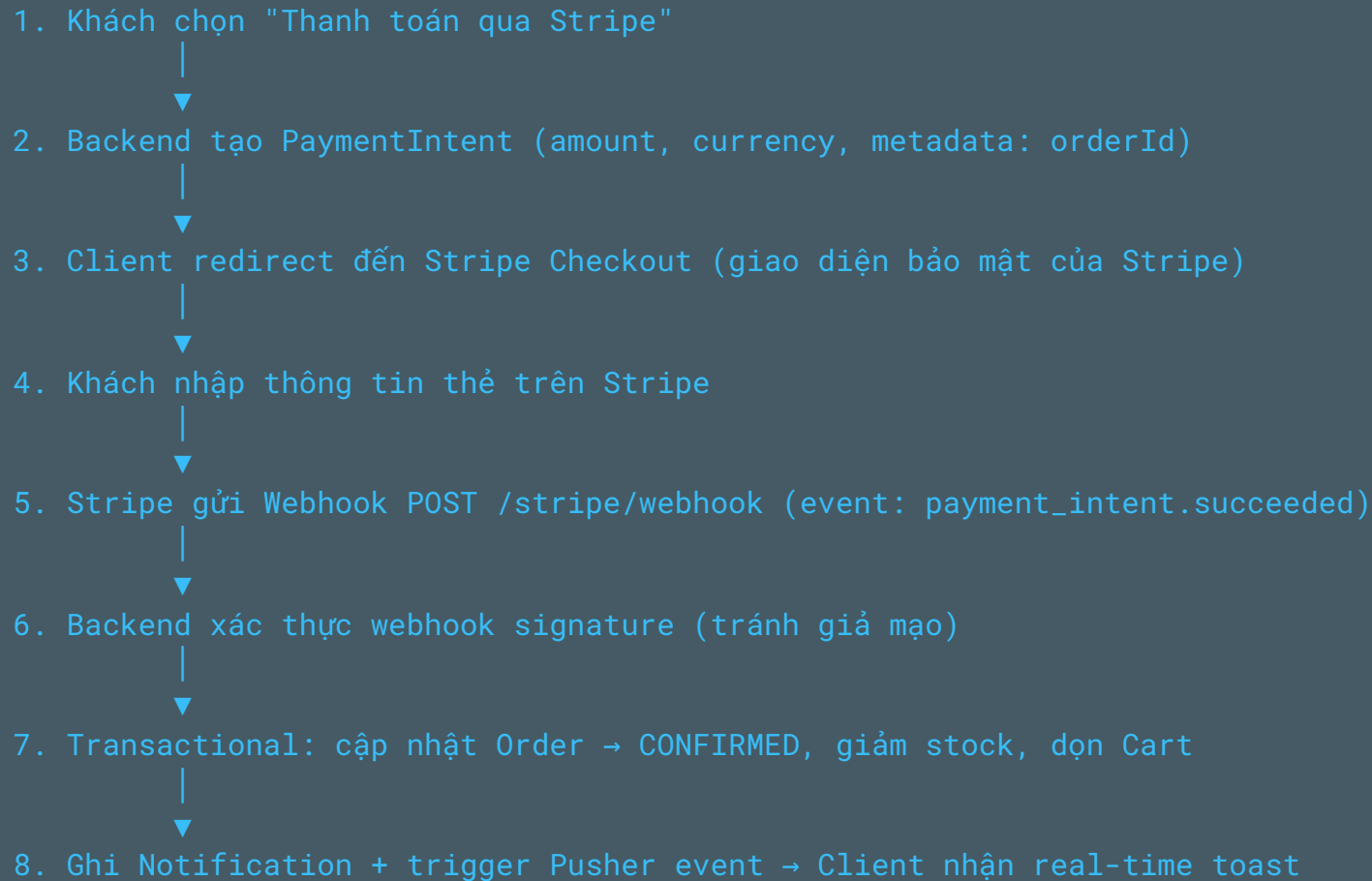


1. Đọc cookie: thử `access_token` TRƯỚC → nếu có → verify → user channel
2. Nếu không có `access_token` → fallback `admin_access_token` → admin channel
3. Nếu cả hai đều không hợp lệ → 401 Unauthorized

- Middleware `protectUserOrAdmin` ưu tiên `access_token` (user) hơn `admin_access_token` (admin)
- Pusher auth endpoint hoàn toàn tách biệt, xác thực thủ công không qua middleware

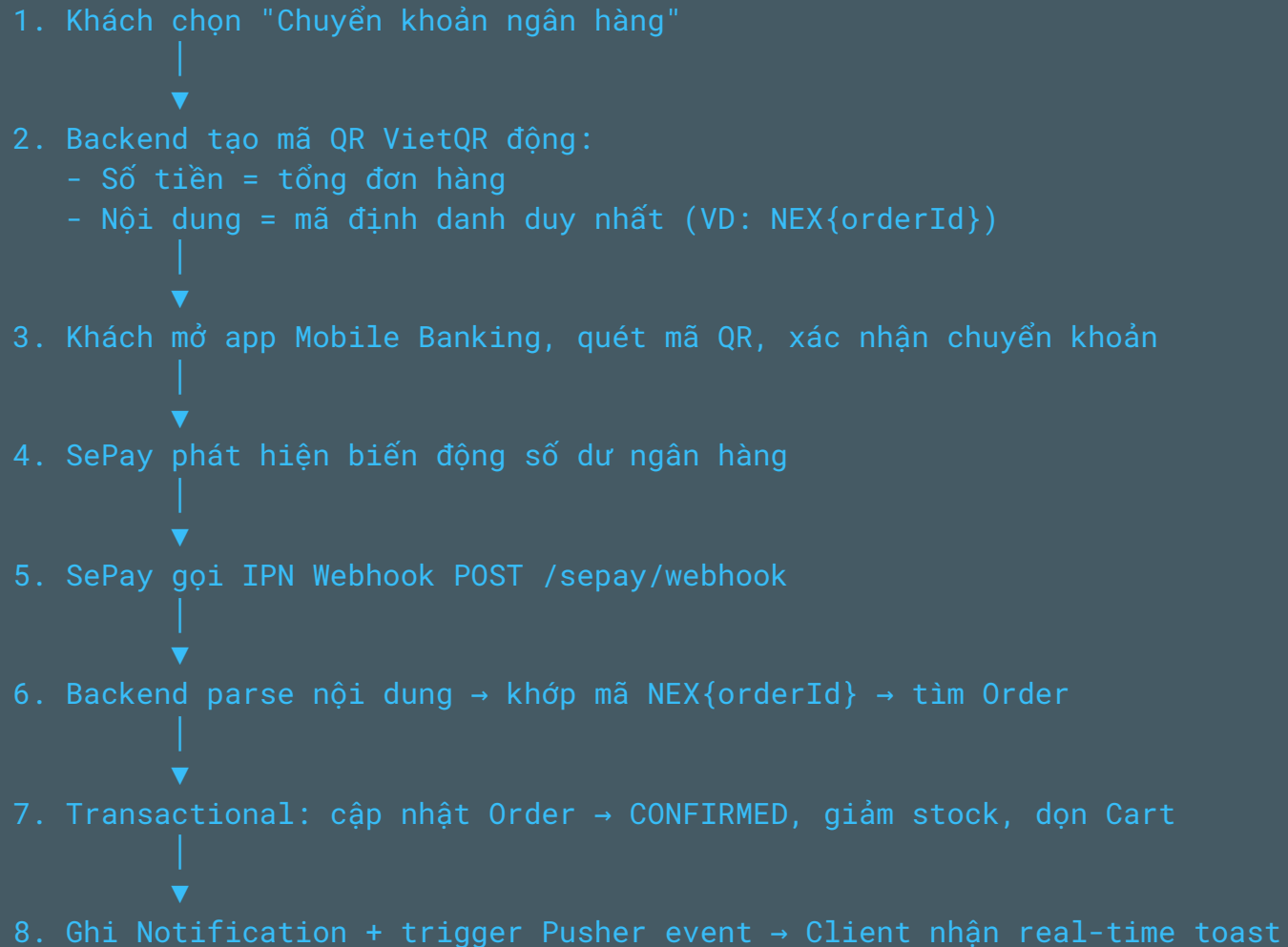
20. Thanh Toán — Stripe (Thẻ Quốc Tế)

Luồng xử lý



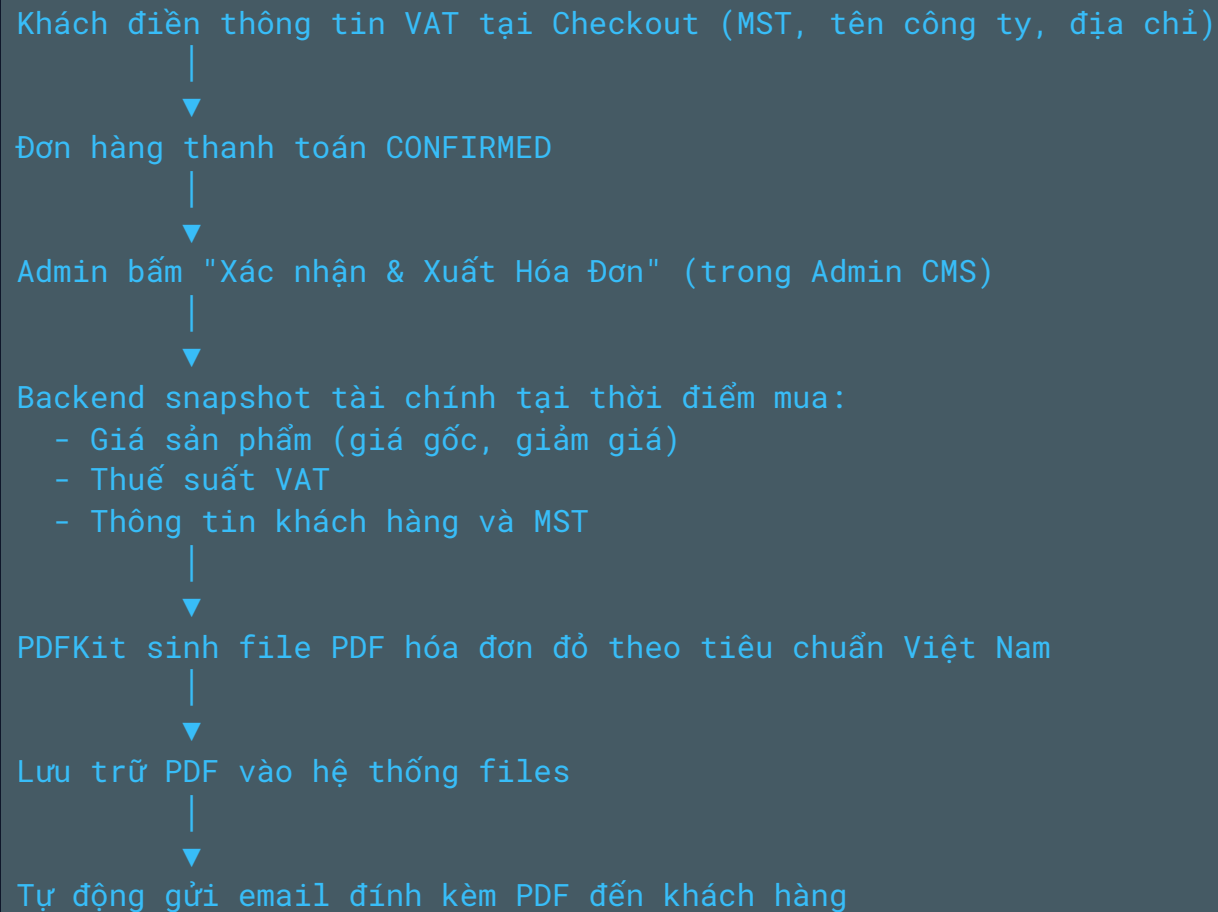
21. Thanh Toán — SePay / VietQR (Chuyển Khoản Nội Địa)

Luồng xử lý



22. Hóa Đơn VAT Điện Tử

Luồng xuất hóa đơn



Immutable Snapshot: Hóa đơn giữ nguyên giá trị tại thời điểm mua — không thay đổi khi giá sản phẩm hay thông tin khách hàng thay đổi sau này.

23. Quản Lý Serial IMEI

Quy trình thao tác

NHẬP KHO:

Admin tạo phiếu nhập (StockImport) → Nhập danh sách IMEI
→ Hệ thống tạo SerialUnit (status: IN_STOCK)

BÁN HÀNG:

Khách đặt hàng → SerialUnit chuyển RESERVED (tạm giữ 15 phút)
→ Khách thanh toán → Admin vào CMS chọn IMEI cụ thể để gán
→ SerialUnit chuyển SOLD, gán với OrderItem

ĐỔI TRẢ:

Khách trả hàng → Admin xác nhận → SerialUnit chuyển RETURNED
→ Tra cứu lại lịch sử: ai mua, khi nào, giá bao nhiêu

- **Truy xuất bảo hành:** Chỉ cần nhập IMEI → tra ra toàn bộ lịch sử
- **Chống trùng lặp:** `@@unique([serialNumber, orderItemId])` tại DB level

24. Real-time Notification & Price Drop Alert

Hệ thống thông báo tức thời

```
Backend ghi Notification vào DB
  |
  ▼
Pusher trigger event đến Soketti
  |
  ▼
Soketti forward event đến client đang subscribe private-user.{userId}
  |
  ▼
client.handleNewNotification():
  1. Badge count increment (headless)
  2. Dropdown content update
  3. sonner.toast.custom() popup (bottom-right, 5 giây)
```

Price Drop Alert — 3 hành động đồng thời

```
Admin giảm giá sản phẩm → Kích hoạt Price Drop Engine
  |
  ▼
Quét bảng Favorite → Tìm user đã yêu thích sản phẩm
  |
  ├── 1. Ghi Notification vào DB
  ├── 2. Trigger Pusher event → Toast real-time trên trình duyệt
  └── 3. Nodemailer + EJS template → Gửi email HTML cảnh báo giá
```

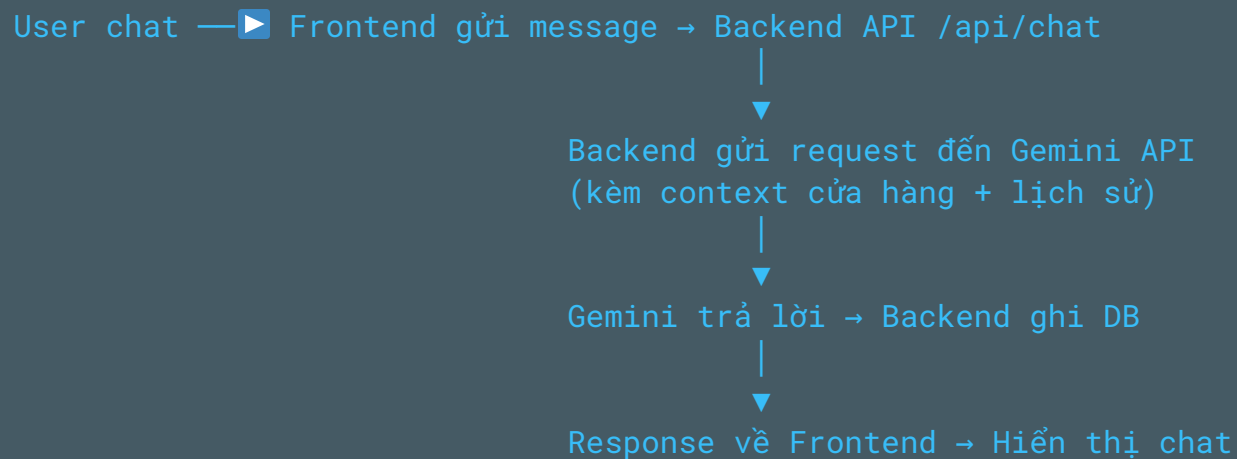
- **Channel bảo mật:** Mỗi user chỉ nhận được thông báo của chính mình

25. AI Chatbot (Gemini API)

Tính năng trợ lý mua sắm thông minh

- **Tích hợp Gemini API:** Xử lý ngôn ngữ tự nhiên, trả lời context-aware
- **Gợi ý sản phẩm:** Dựa trên câu hỏi của khách hàng ("Tìm laptop dưới 15 triệu cho sinh viên")
- **Hỗ trợ đặt hàng:** Hướng dẫn quy trình mua hàng, check trạng thái đơn
- **Lịch sử hội thoại:** Lưu vào bảng `AIChatMessage` (role user/assistant) — không mất context khi refresh

Architecture



26. Tác Vụ Nền Định Kỳ (Cron Jobs)

Sử dụng `node-cron` chạy trong cùng tiến trình backend — không cần Redis, phù hợp quy mô hiện tại.

Tác vụ	Chu kỳ	Chức năng
<code>expirationJob</code>	1 phút	Hủy đơn PENDING quá 15 phút → hoàn trả stock RESERVED về IN_STOCK
<code>lowStockJob</code>	1 giờ	Quét SerialUnit → nếu dưới <code>lowStockThreshold</code> → email cảnh báo Admin
<code>lowOrderAlertJob</code>	Theo config	Theo dõi tần suất đơn hàng → cảnh báo Store Owner nếu bất thường
<code>publishScheduledPostsJob</code>	1 phút	Đăng bài viết đã lên lịch hẹn giờ (<code>scheduledAt ≤ now</code>)
<code>scheduledEmailJob</code>	30 phút	Retry email từ bảng <code>FailedEmail</code> (SMTP lỗi tạm thời)

→ *Hạn chế*: Khi cần scale backend lên nhiều instances, cần nâng cấp lên **Redis + BullMQ**.

27. CI/CD Pipeline

GitHub Actions → GHCR → VPS

Developer push commit lên nhánh main



GitHub Actions Workflow được kích hoạt:



1. Checkout code
2. ESLint kiểm tra lỗi cú pháp (frontend + backend)
3. Docker Buildx build image (multi-platform)
4. Push image lên GitHub Container Registry (GHCR)
5. SSH vào VPS thực thi lệnh:



Trên VPS:

- docker compose pull (tải image mới từ GHCR)
- docker compose up -d (restart container với image mới)
- npx prisma migrate deploy (migration database tự động)

Zero downtime: Nginx vẫn phục vụ request cũ trong lúc container mới khởi động.

28. Kết Quả Demo & Tài Khoản

Địa chỉ Live

Ứng dụng	URL
Frontend User	nextech.io.vn
Admin CMS	admin.nextech.io.vn
Swagger API Docs	api.nextech.io.vn/api-docs

Tài khoản trải nghiệm

Vai trò	Email	Mật khẩu
Quản trị viên (Admin)	admin@nextech.com	Admin123!
Khách hàng (User 1)	user1@nextech.com	User123!
Khách hàng (User 2)	user2@nextech.com	User123!

Thành quả chính

- ✓ Hệ thống **Monorepo** hoàn chỉnh: 3 ứng dụng chạy ổn định trên Docker
- ✓ **Thanh toán kép tự động** qua Webhook (Stripe + SePay)
- ✓ **Quản lý IMEI/Serial** vòng đời 4 trạng thái, tra cứu bảo hành
- ✓ **Hóa đơn VAT PDF** tự động, immutable snapshot
- ✓ **Real-time WebSocket** (Soketi): toast, badge, price drop
- ✓ **Bảo mật**: IWT HttpOnly rotation, Pusher private channel auth

29. Kết Luận, Hạn Chế & Hướng Phát Triển

Hạn chế

Vấn đề	Hiện tại	Cải thiện
Cron chung process	<code>node-cron</code>	Redis + BullMQ
Chưa có unit test	Thủ công	Jest/Vitest
Chatbot cơ bản	Gemini API	Fine-tune riêng

Hướng phát triển

- AI cá nhân hóa gợi ý sản phẩm, chatbot giọng nói
- Multi-warehouse, Mobile App (React Native), Multi-language

XIN CHÂN THÀNH CẢM ƠN HỘI ĐỒNG!

Q&A — Mời quý Thầy/Cô và các bạn đặt câu hỏi!

- **Email:** trungdang.dqt@gmail.com
- **GitHub:** [Quang-Trung-68](#)